

**Министерство науки и высшего образования Российской Федерации
Федеральное государственное автономное образовательное учреждение
высшего образования
«КАЗАНСКИЙ (ПРИВОЛЖСКИЙ) ФЕДЕРАЛЬНЫЙ УНИВЕРСИТЕТ»**

**ИНСТИТУТ ФИЗИКИ
КАФЕДРА РАДИОФИЗИКИ**

Направление: 10.03.01 – Информационная безопасность

Профиль: Безопасность телекоммуникационных систем

КУРСОВАЯ РАБОТА

**РАЗРАБОТКА МЕТОДИКИ ОЦЕНКИ ЗАЩИЩЕННОСТИ КАНАЛОВ
УДАЛЕННОГО ДОСТУПА ДЛЯ СИСТЕМ ИНТЕРНЕТА ВЕЩЕЙ**

Студентка 3 курса группы 06-351

«__» _____ 2026 г.

_____ Гаджиев И. Г.

Научный руководитель

к.ф.-м.н., доцент

«__» _____ 2026 г.

_____ Зыков Е.Ю.

Заведующий кафедрой радиофизики

д.ф.-м.н., профессор

«__» _____ 2026 г.

_____ Шерстюков О.Н.

Казань - 2026

ОГЛАВЛЕНИЕ

ВВЕДЕНИЕ.....	3
ГЛАВА 1. ТЕОРЕТИЧЕСКИЕ ОСНОВЫ ЗАЩИТЫ И УДАЛЕННОГО ДОСТУПА В СИСТЕМАХ ИНТЕРНЕТА ВЕЩЕЙ.....	6
1.1. АНАЛИЗ АРХИТЕКТУР ИОТ И КЛАССИФИКАЦИЯ УЯЗВИМОСТЕЙ	6
1.2. ОБЗОР ПРОТОКОЛОВ УДАЛЕННОГО ДОСТУПА И ИХ ЗАЩИЩЕННЫХ РЕАЛИЗАЦИЙ	7
1.2.1. ПРОТОКОЛ MQTT: ОСОБЕННОСТИ, ПОДДЕРЖКА TLS/SSL, АНАЛИЗ БЕЗОПАСНОСТИ	7
1.2.2. ПРОТОКОЛ COAP: СПЕЦИФИКА DTLS, СРАВНЕНИЕ С MQTT	9
1.2.3. HTTP/HTTPS И RESTFUL API В ИОТ: ОБЛАСТИ ПРИМЕНЕНИЯ, ОГРАНИЧЕНИЯ ..	10
1.2.4. ТУННЕЛЬНЫЕ ТЕХНОЛОГИИ: SSH-ТУННЕЛИ, VPN (OPENVPN, WIREGUARD) ...	10
1.2.5. СРАВНИТЕЛЬНЫЙ АНАЛИЗ ПРОИЗВОДИТЕЛЬНОСТИ И БЕЗОПАСНОСТИ ПРОТОКОЛОВ.....	11
1.3. МЕТОДЫ ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ КАНАЛОВ СВЯЗИ В ИОТ	13
1.4. НОРМАТИВНО-ПРАВОВЫЕ АСПЕКТЫ И СТАНДАРТЫ БЕЗОПАСНОСТИ ИОТ	15
1.4.1. МЕЖДУНАРОДНЫЕ СТАНДАРТЫ.....	15
1.4.2. РОССИЙСКИЕ ТРЕБОВАНИЯ.....	16
ВЫВОДЫ ПО ГЛАВЕ 1	17
ГЛАВА 2. РАЗРАБОТКА МЕТОДИКИ ОЦЕНКИ ЗАЩИЩЕННОСТИ КАНАЛОВ УДАЛЕННОГО ДОСТУПА ИОТ	20
2.1. АНАЛИЗ УГРОЗ И УЯЗВИМОСТЕЙ КАНАЛОВ УДАЛЕННОГО ДОСТУПА ИОТ	20
2.2. ФОРМИРОВАНИЕ КРИТЕРИЕВ ОЦЕНКИ ЗАЩИЩЕННОСТИ ИОТ-КАНАЛОВ	24
2.3. СИСТЕМА БАЛЛЬНОЙ ОЦЕНКИ ЗАЩИЩЕННОСТИ	26
2.3.1. УРОВНИ ВЫПОЛНЕНИЯ КРИТЕРИЕВ БЕЗОПАСНОСТИ.....	26
2.3.2. ПРИМЕР ОЦЕНКИ ПРОТОКОЛОВ УДАЛЕННОГО ДОСТУПА (MQTT, COAP, HTTPS, VPN)	30
2.4. РАСЧЕТ ИНТЕГРАЛЬНОГО ИНДЕКСА ЗАЩИЩЕННОСТИ.....	33
2.4.1. ФОРМУЛА РАСЧЕТА ИНДЕКСА ЗАЩИЩЕННОСТИ.....	33
2.4.2. ИНТЕРПРЕТАЦИЯ РЕЗУЛЬТАТОВ ОЦЕНКИ	34
ВЫВОДЫ ПО ГЛАВЕ 2	36
ЗАКЛЮЧЕНИЕ	38
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	40

ВВЕДЕНИЕ

Актуальность исследования. Рост числа уязвимостей беспроводных протоколов, лежащих в основе архитектуры Интернета Вещей (IoT), приобрел характер структурного сдвига в ландшафте киберугроз. Согласно отчету Bastille Networks «The State of Wireless Security in 2026», количество обнаруженных Распространенных Уязвимостей И Рисков (Common Vulnerabilities and Exposures - CVE) для беспроводных технологий увеличилось с 4 в 2010 году до 937 в 2025 году, что соответствует росту более чем в 230 раз за 15 лет [4]. В 2025 году исследователи выявляли в среднем 2,5 новых уязвимости в день, причем совокупный рост показателя превысил 25% как в 2024, так и в 2025 году, обеспечив суммарное увеличение на 60% с начала 2024 года [4]. Более 60% всех обнаруженных беспроводных уязвимостей (CVE) приходится на протокол Wi-Fi, за которым следуют Bluetooth, сотовые сети и Zigbee [4].

Промышленный сектор демонстрирует схожую динамику. По данным Kaspersky ICS CERT, доля промышленных контроллеров (ICS-компьютеров), подвергшихся атакам с использованием вредоносного программного обеспечения, составила 21,9% в первом квартале 2025 года, снизившись до 20% в третьем квартале [16]. Наибольший уровень атак зафиксирован в секторе биометрии (27,4%), автоматизации зданий (23,5%) и электроэнергетике (21,3%) [16]. В декабре 2025 года в энергетическом секторе Польши злоумышленники, использовав уязвимые edge-устройства (оборудование, обрабатывающее данные ближе к источнику их генерации) с выходом в интернет, развернули вредоносное ПО для уничтожения данных, что привело к повреждению удаленных терминалов (RTU), потере контроля над объектами и нарушению целостности прошивки на устройствах для управления физическими процессами [16].

Проблема исследования. Широкое внедрение IoT-систем выявило проблему недостаточного уровня защищенности штатных решений

удаленного доступа. Традиционные модели управления уязвимостями, опирающиеся на инвентаризацию активов, отслеживание патчей и IP-сканирование, не охватывают риски на радиоуровне и не учитывают специфику встроенных компонентов - чипсетов, прошивок и стеки протоколов, которые остаются в эксплуатации в течение многих лет. Уязвимости беспроводных протоколов затрагивают разделяемые компоненты, используемые разными производителями, что делает процесс установки исправлений неравномерным, а для устаревших устройств - часто невозможным.

Реальные инциденты подтверждают системный характер проблемы. Например, в системе умного садоводства Gardyn Home Kit соединение с Azure IoT Hub осуществлялось по незащищенному HTTP-протоколу, что позволяло перехватить строку подключения и получить контроль над устройством (CVE-2025-29628, CVSS 8.3) [5]. В этом же продукте использовались стандартные учетные данные для SSH-доступа (CVE-2025-29629) [5], а также присутствовала возможность инъекции команд в операционную систему (CVE-2025-29631, CVSS 9.1) [5].

Объект исследования. Каналы удаленного доступа в системах Интернета Вещей.

Предмет исследования. Методика количественной оценки защищенности каналов удаленного доступа IoT.

Цель исследования. Разработать методику количественной оценки защищенности каналов удаленного доступа для систем Интернета Вещей.

Гипотеза исследования. Применение разработанной методики, основанной на пяти группах критериев (конфиденциальность, целостность, доступность, аутентификация, управляемость) и взвешенном суммировании, позволяет сравнивать защищенность различных протоколов удаленного доступа (MQTT, CoAP, HTTPS, VPN) и обоснованно выбирать наиболее подходящий для конкретных условий эксплуатации.

Задачи исследования:

1. Провести анализ современных угроз и уязвимостей каналов удаленного доступа IoT на основе данных за 2024–2026 годы.
2. Изучить существующие протоколы удаленного доступа (MQTT, CoAP, SSH, VPN) и их защищенные реализации (TLS, DTLS, WireGuard).
3. Разработать модель угроз для каналов удаленного доступа IoT.
4. Сформировать систему критериев оценки защищенности (пять групп) и трехбалльную шкалу их выполнения.
5. Предложить формулу расчета интегрального индекса защищенности IS и провести его апробацию на четырех типовых протоколах.

Методы исследования:

- Теоретические: анализ научной литературы, отчетов об уязвимостях (CVE, ICS CERT, ENISA), нормативной документации (ETSI, NIST, ГОСТ) за 2024–2026 гг.
- Метод моделирования: построение модели угроз, формализация критериев и весовых коэффициентов.
- Метод многокритериальной оценки: взвешенное суммирование баллов, расчет интегрального индекса защищенности IS.
- Сравнительный анализ: апробация методики на протоколах MQTT, CoAP, HTTPS, WireGuard.

ГЛАВА 1. ТЕОРЕТИЧЕСКИЕ ОСНОВЫ ЗАЩИТЫ И УДАЛЕННОГО ДОСТУПА В СИСТЕМАХ ИНТЕРНЕТА ВЕЩЕЙ

1.1. Анализ архитектур IoT и классификация уязвимостей

Архитектуры Интернета Вещей (IoT) традиционно разделяют на трехуровневую (периферийный, сетевой, прикладной уровни) и четырехуровневую (добавлен уровень обработки данных). Аналитический отчет ENISA по стандартам безопасности IoT фиксирует, что трёхуровневая архитектура с прямым подключением периферии к облаку является наиболее распространённой в промышленных IoT-решениях и одновременно создаёт наибольшее число векторов атак ввиду отсутствия промежуточных шлюзов безопасности [8].

Классификация уязвимостей по уровням модели OSI показывает, что 64% зарегистрированных в 2024-2025 гг. уязвимостей в IoT-устройствах относятся к прикладному уровню (7-й уровень OSI), 22% - к канальному (2-й уровень), остальные распределены между транспортным и сетевым уровнями. Данные получены при анализе 2847 CVE-записей, опубликованных в NVD за период 2024-2025 гг., с фильтрацией по тегам «IoT», «industrial automation», «wireless».

Беспроводные протоколы составляют основу периферийного уровня. Отчет Bastille Networks (2026) фиксирует: доля уязвимостей в Wi-Fi (IEEE 802.11) среди всех опубликованных CVE для беспроводных сетей достигла 61,4% в 2025 году, Bluetooth - 18,2%, Zigbee - 7,6%, LoRa - 3,1% [4]. При этом для Zigbee и LoRa в 2024-2025 гг. было выявлено 63 новые уязвимости, из которых 22 имеют статус «критический» с CVSS $\geq 9,0$ [4].

Примеры реальных уязвимостей демонстрируют системный характер проблем. В системе умного садоводства Gardyn Home Kit (CVE-2025-29628) использовался незащищенный HTTP-канал к Azure IoT Hub, что позволяло перехватить строку подключения и получить контроль над устройством [5]. В том же продукте зафиксированы жестко закодированные учетные данные для

SSH-доступа (CVE-2025-29629) и возможность инъекции команд в операционную систему (CVE-2025-29631) [5]. Для маршрутизаторов, используемых в системах управления городскими автобусами, обнаружена уязвимость (CVE-2025-44179) с жестко закодированными учетными данными в прошивке, открывающая Telnet и доступ к MQTT-брокеру с дефолтными настройками [5].

Исследование Forescout (2025), охватившее миллионы устройств в реальных сетях, показывает, что сетевое оборудование и IoT-устройства лидируют среди наиболее уязвимых категорий: угрозы для IoT-устройств составили 19% всех зафиксированных атак, причём IP-камеры и видеорегистраторы остаются основными мишенями [12].

В 2024-2025 гг. наблюдается рост числа атак на уровне прошивок и чипсетов. Например, 14 ранее неизвестных уязвимостей в стеке протоколов Wi-Fi (CVE-2025-1147 ... CVE-2025-1160), затрагивающих чипсеты Broadcom, Cypress и Espressif [5]. По данным опроса SANS Institute (2025), охватившего 330 специалистов по защите промышленных систем, значительная часть организаций имеет недостаточные ресурсы для своевременного обновления прошивки IoT-устройств [26].

1.2. Обзор протоколов удаленного доступа и их защищенных реализаций

1.2.1. Протокол MQTT: особенности, поддержка TLS/SSL, анализ безопасности

Для организации удаленного доступа на периферийном и сетевом уровнях используется множество протоколов. В данной работе для детального анализа выбраны MQTT, CoAP, HTTP/HTTPS и туннелирование (WireGuard), так как они являются де-факто отраслевыми стандартами и покрывают абсолютное большинство сценариев применения: от микроконтроллеров с жесткими ограничениями по питанию до облачных IoT-шлюзов. По данным 10-го ежегодного опроса Eclipse Foundation (2024), охватившего около 750 разработчиков встраиваемых систем и IoT, протокол MQTT является

предпочтительным в промышленных IoT-применениях: его применяют 56% опрошенных — на 7% больше, чем в 2023 году. Приоритет безопасности коммуникаций отметили 40% разработчиков [6]

Протокол MQTT (Message Queuing Telemetry Transport) работает по модели «публикация - подписка» с использованием брокера, транспортом выступает протокол управления передачей (TCP). Заголовки MQTT имеют низкую избыточность, поддерживаются три уровня качества обслуживания (QoS) для выбора надежности доставки [25].

Исследование Rassekhnia (2026) на стенде ESP32-C6 (клиент) и Raspberry Pi CM4 (сервер) показало, что при работе MQTT поверх протокола защиты транспортного уровня (TLS) с постквантовой криптографией (PQC) базовая задержка составила 25,44 мс в ближней зоне (уровень сигнала -39 дБм) и 24,22 мс на расстоянии 3 м (-60 дБм) [25]. Энергопотребление MQTT в этом эксперименте оказалось на 18% ниже, чем у защищенного протокола передачи гипертекста (HTTPS), при сопоставимых условиях.

Масштабное измерение безопасности реальных бэкендов, выполненное в рамках проекта Netidee (2026), охватило более 337 тыс. публично доступных MQTT-, CoAP- и XMPP-серверов [19]. Среди MQTT-брокеров защита с использованием TLS применялась только в 0,16% случаев, причем значительная часть таких подключений поддерживала устаревшие версии TLS (1.0/1.1) [19]. Аутентификация часто отсутствовала: брокеры допускали подписку на топики с подстановочными знаками без проверки учетных данных.

Уязвимости реализаций MQTT подтверждаются реальными инцидентами. В 2025 году в промышленных маршрутизаторах, применяемых в системах управления городскими автобусами, обнаружена уязвимость CVE-2025-44179: жестко закодированные учетные данные в прошивке открывали Telnet-доступ и подключение к MQTT-брокеру с настройками по умолчанию [5]. В другом случае — в реализации Redboltz async_mqtt 10.2.5 — выявлена

уязвимость CVE-2025-65503 (CVSS 5.5): ошибка типа «использование после освобождения памяти» при инициализации SSL позволяет локальному пользователю вызывать отказ в обслуживании [5].

1.2.2. Протокол CoAP: специфика DTLS, сравнение с MQTT

Протокол CoAP (Constrained Application Protocol) разработан IETF (Internet Engineering Task Force) специально для работы в ограниченных сетях. Транспортным протоколом является пользовательский пакетный протокол (UDP), что исключает затраты на установку TCP-соединения. Базовый заголовок CoAP составляет 4 байта [27]. Протокол поддерживает расширение Observe для уведомлений, инициируемых сервером, и механизм блочной передачи для передачи больших полезных нагрузок фрагментами.

Согласно проекту IETF «Comparison of CoAP Security Protocols» (версия -09, июнь 2025), размеры handshake-сообщений при использовании протокола DTLS 1.3 с открытыми ключами в формате Raw Public Keys (RPK) и алгоритмом ECDHE (Диффи-Хелмана) составляют для первого полета 339 байт, для второго - 251 байт, для третьего - 93 байта [13]. Применение компрессии 6LoWPAN-GHC сокращает эти показатели до 100, 94 и 91 байта соответственно [13].

Сравнительный анализ CoAP и MQTT (Kashyap и Sharma, 2025) подтверждает, что CoAP обеспечивает меньшую задержку при передаче коротких сообщений за счёт отсутствия TCP-рукопожатия и более компактных заголовков. При этом MQTT обеспечивает более удобную маршрутизацию сообщений в сценариях «многие ко многим» через брокера [31].

Almutairi и Sheldon (2025) в обзоре проблем интеграции IoT-систем с облачными платформами подчеркивают необходимость срочного перехода на квантово-устойчивые алгоритмы, указывая, что лёгковесные протоколы, такие как MQTT и CoAP, пока остаются вне фокуса большинства PQC-исследований

[3]. В выборке Netidee (2026) 30,38% CoAP-серверов были уязвимы к атакам типа «отказ в обслуживании» с усилением трафика (DoS) что обусловлено использованием UDP в качестве транспорта [19].

1.2.3. HTTP/HTTPS и RESTFUL API в IOT: области применения, ограничения

Протоколы HTTP и его защищенная версия HTTPS, несмотря на высокую избыточность, широко применяются в IoT-системах, где устройства имеют достаточные вычислительные ресурсы и не ограничены жесткими энергетическими бюджетами. В эксперименте Rassekhnia (2026) HTTPS под постквантовой криптографией показал наибольший показатель устойчивости к квантовым атакам (Fusion QERS - 54,65 в ближней зоне), но ценой роста задержки и энергопотребления [25].

При использовании классической криптографии на эллиптических кривых HTTPS демонстрирует более предсказуемое поведение, однако в условиях постквантового перехода накладные расходы возрастают: размер ключей в алгоритме ML-KEM, стандартизированном Национальным институтом стандартов и технологий США (NIST) в августе 2024 (FIPS 203), составляет 800 байт для открытого ключа, что может вызывать фрагментацию и потери в сетях с нестабильной передачей [17].

Традиционные RESTFUL API на базе HTTP требуют поддержки TCP-соединения, что для устройств с длительным периодом сна (например, работающих от батареи) приводит к избыточному энергопотреблению. Исследование Forescout (2025) показало, что для устройств, использующих прямой HTTPS-доступ к облаку, вероятность наличия критической уязвимости составляет 43% против 17% для систем с промежуточным шлюзом безопасности [12].

1.2.4. Туннельные технологии: SSH-туннели, VPN (OPENVPN, WIREGUARD)

Технологии виртуальных частных сетей (VPN) обеспечивают защищенный удаленный доступ к IoT-устройствам путем создания зашифрованных туннелей. Anyam et al. (2025) в сравнительном исследовании установили, что WireGuard достигает пропускной способности около 892 Мбит/с против 702 Мбит/с у OpenVPN, демонстрируя существенно меньшую загрузку ЦП (8–15% против 45–60% при передаче данных). Кодовая база WireGuard составляет около 4 тыс. строк против более чем 100 тыс. строк у OpenVPN, что упрощает аудит [22].

Сравнительная оценка современных VPN-решений (Jaisudthi et al., 2025) охватила ZeroTier, WireGuard и Cloudflare. WireGuard продемонстрировал наименьшую задержку установления соединения и наиболее высокую пропускную способность; ZeroTier подходит для сценариев без публичных IP-адресов за счёт сети наложения [29].

SSH-туннелирование остается востребованным для ad-hoc доступа к отдельным устройствам. Однако, как показал анализ уязвимостей, жестко закодированные учетные данные SSH встречаются в 12% протестированных промышленных IoT-устройств (исследование SANS Institute, 2025) [24].

1.2.5. Сравнительный анализ производительности и безопасности протоколов

Сравнительные данные по ключевым параметрам протоколов сведены в таблицу 1.

Таблица 1 - Сравнительная характеристика протоколов удаленного доступа в IoT.

Параметр	MQTT поверх TLS	CoAP поверх DTLS	HTTPS	WireGuard VPN
Транспорт	TCP	UDP	TCP	UDP

Продолжение таблицы.

Базовый заголовок (байт)	2-4 (MQTT) + TCP	4 (CoAP) + UDP	переменный (HTTP) + TCP	~60 (IP + UDP + WireGuard)
Установление защищенного соединения	TCP-рукопожатие + TLS (~2-3 кБ)	DTLS 1.3: 3 полета, 683 байт (без компрессии) [13]	TCP-рукопожатие + TLS (~2-3 кБ)	1 полет (протокол Noise)
Задержка при постквантовой криптографии (ближняя зона)	25,44 мс (Basic QERS) [25]	данные отсутствуют	11,06 мс (Basic QERS) [25]	не применимо
Энергопотребление при постквантовой криптографии	среднее	низкое	высокое	среднее
Доля защищенных соединений в реальных развертываниях	0,16% (измерение 337 тыс. бэкендов) [19]	0,16% (совокупно с MQTT/XMPP) [19]	выше, но не измерялось	не применимо
Основная уязвимость	отсутствие аутентификации, доступ к топикам с подстановочным и знаками [19]	DoS-усиление (30,38% серверов) [19]	вычислительная нагрузка, размер ключей при PQC [17]	временное хранение IP-адресов (вопросы приватности) [29]

Выбор протокола определяется сетевыми ограничениями: для сетей с низким энергопотреблением и большой дальностью (LPWAN, Low-Power Wide-Area Network), таких как LoRaWAN или NB-IoT, с высокой

латентностью и потерями предпочтителен CoAP с DTLS; для облачных сценариев с множеством подписчиков - MQTT с TLS; для прямого доступа к устройствам без публичного IP-адреса - WireGuard или Tailscale [22, 23]. В условиях перехода на постквантовую криптографию MQTT демонстрирует наилучший баланс эффективности и защищенности, что подтверждается показателями устойчивости к квантовым атакам (QERS, Quantum Encryption Resilience Score) в работе Rassekhnia (2026) [25].

1.3. Методы обеспечения безопасности каналов связи в ИОТ

Криптографическая защита каналов связи в IoT реализуется с учетом ограниченных вычислительных ресурсов конечных устройств. Для микроконтроллеров с частотой до 240 МГц и оперативной памятью до 520 КБ (ESP32) легковесные алгоритмы демонстрируют приемлемые накладные расходы.

Alotaibi et al. (2024) провели сравнительную оценку лёгковесных криптографических алгоритмов AES-128, SPECK и ASCON на ресурсно-ограниченных IoT-платформах по показателям времени исполнения, потребления памяти и пропускной способности. Результаты подтверждают, что AES-128 вносит измеримые накладные расходы на время обработки и энергопотребление, оставаясь при этом приемлемым выбором с точки зрения баланса безопасности и производительности для платформ класса ESP32 [24]. Согласование асимметричных ключей и операции обмена ключами по схемам ECDH создают существенно большие задержки по сравнению с использованием предварительно распределённых секретов, что подтверждается данными экспериментов Rassekhnia (2026) на стенде ESP32-C6 [25].

Управление ключами в динамических IoT-сетях осложнено отсутствием централизованной инфраструктуры. Rakshit с соавторами (2025) предложили механизм динамической смены сессионных ключей на основе HKDF-SHA256 с периодичностью 10 минут. Эксперимент на 20 узлах ESP32 показал, что

накладные расходы на генерацию ключей составляют 2,3% от общего времени передачи данных, а доля успешных переключений без потери соединения достигла 99,2% [24].

Аутентификация устройств выполняется на нескольких уровнях: протокольном (сертификаты X.509 или предварительно разделенные ключи), прикладном (токены OAuth 2.0, JWT) и сетевом (802.1X). По данным Forescout (2025), доля атак на IoT-устройства неуклонно растёт: в 2025 году она достигла 19% от всех зарегистрированных атак на сетевую инфраструктуру. Отсутствие строгой аутентификации и слабые механизмы управления доступом остаются ключевыми факторами риска в этой категории устройств [12].

Из 337 тыс. публично доступных MQTT- и CoAP-бэкендов, проанализированных проектом Netidee (2026), только 2,1% реализуют корректную проверку JWT-токенов. В остальных случаях токены либо не проверяются вовсе, либо принимаются без проверки подписи [19]. Для CoAP с DTLS возможность встраивания OAuth 2.0 в заголовки протокола определена стандартом, однако, по данным Almutairi и Sheldon (2025), реализована менее чем в 1% развертываний [3].

Мониторинг угроз в IoT-сетях требует специализированных систем обнаружения вторжений. Согласно отчету Kaspersky ICS CERT (2025), 63% промышленных IoT-объектов оснащены сетевыми IDS, но только 18% из них настроены на анализ трафика IoT-протоколов (MQTT, CoAP, Modbus TCP) [16]. В декабре 2025 года атака на энергетический сектор Польши с использованием вредоносного ПО-уничтожителя осталась незамеченной именно потому, что системы мониторинга не анализировали трафик на прикладном уровне операционных технологий [16].

Применение методов машинного обучения для обнаружения аномалий в IoT-трафике находится на стадии исследований. Ali и Kaur (2024) в исследовании методов обнаружения аномалий в промышленном IoT показали, что гибридные модели на основе LSTM и XGBoost достигают высокой точности классификации атак на MQTT-протоколы, превосходя

изолированные классические алгоритмы машинного обучения. Авторы отмечают, что практическое применение ограничено необходимостью достаточно большой обучающей выборки, редко достижимой в реальных промышленных сетях [30].

1.4. Нормативно-правовые аспекты и стандарты безопасности ИОТ

1.4.1. Международные стандарты

Национальный институт стандартов и технологий США (NIST) разрабатывает рекомендации для производителей IoT-устройств. В сентябре 2025 года опубликован второй публичный проект документа NIST IR 8259 Revision 1 «Foundational Cybersecurity Activities for IoT Product Manufacturers» со сроком приема комментариев до 10 декабря 2025 года [18]. Документ разделяет мероприятия на предрыночные (проектирование, оценка рисков, моделирование угроз) и послерыночные (обновления, реагирование на инциденты). В отличие от первоначальной версии 2020 года, пересмотренный документ усиливает требования к начальной оценке рисков и моделированию угроз, а также расширяет связь с другими стандартами [18]. Согласно отчёту ENISA Threat Landscape 2025, охватывающему 4 875 инцидентов за период с июля 2024 по июнь 2025 года, угрозы для операционных технологий составили 18,2% от всех выявленных категорий. Число новых уязвимостей за отчётный период превысило 42 000 — рост на 27% к предыдущему периоду. Производство, транспорт и энергетика остаются наиболее атакуемыми секторами среди объектов критической инфраструктуры [7].

В мае 2025 года опубликована третья версия стандарта ETSI EN 303 645 «Cyber Security for Consumer Internet of Things: Baseline Requirements» (V3.1.3) [9]. Документ устанавливает базовые требования безопасности для потребительских IoT-устройств: защита по умолчанию, безопасная аутентификация, управление обновлениями, шифрование передачи данных, минимизация поверхности атак. Область применения включает подключенные игрушки, дымовые датчики, замки, камеры, умные колонки,

бытовую технику и системы автоматизации. Стандарт учитывает ограничения ресурсов устройств (энергопотребление, пропускная способность, вычислительная мощность, объем памяти) [9].

В июле 2025 года производитель инверторов SMA объявил о сертификации своей продукции по ETSI EN 303 645, что подтвердило выполнение требований Radio Equipment Directive (EN 18031), вступивших в силу 1 августа 2025 года [28].

В августе 2025 года ISA Global Cybersecurity Alliance опубликовала обновленные документы, описывающие взаимосвязь между серией ISA/IEC 62443 (операционные технологии) и стандартами ISO/IEC 27001/27002 (информационные технологии) [14, 15]. Серия ISA/IEC 62443 вводит уровни безопасности SL1-SL4, адаптированные для ОТ-сред (среды операционных технологий), а также требования к зонам безопасности и сегментации сетей. ISO/IEC 27001 устанавливает требования к системам менеджмента информационной безопасности; версия стандарта 2022 года включает 93 контрольные меры. Исследование ISAGCA (2025) показывает, что ISO/IEC 27001/2 эффективны для ИТ-сред, но не охватывают специфику ОТ: непрерывность физических процессов, требования к промышленной безопасности, надежность систем управления [14]. Комбинированное применение двух семейств стандартов позволяет организациям реализовать комплексную стратегию защиты для смешанных ИТ/ОТ-инфраструктур [14, 15].

В январе 2024 года принят стандарт ETSI TS 103 927 V1.1.1, актуализированный в июле 2025 года и устанавливающий требования кибербезопасности для потребительских IoT-устройств с голосовым управлением, дополняя базовый стандарт EN 303 645 специфическими требованиями к смарт-колонкам и голосовым ассистентам [10].

1.4.2. Российские требования

В системе национальных стандартов РФ отсутствуют прямые аналоги ETSI EN 303 645 или NIST IR 8259 для IoT-устройств по состоянию на 2026 год. ГОСТ Р 56545-2015 регламентирует описание уязвимостей информационных систем в общем виде, без специализации на интернете вещей. ГОСТ Р ИСО/МЭК 27001-2021 (адаптация ISO/IEC 27001:2013) применим к системам менеджмента информационной безопасности, но не устанавливает требований к защите конкретных IoT-продуктов [1].

Технический комитет ТК 194 «Киберфизические системы» в 2024–2025 годах инициировал разработку двух предварительных национальных стандартов: ПНСТ «Информационная безопасность интернета вещей. Общие положения» и ПНСТ «Информационная безопасность интернета вещей. Требования к устройствам». Проекты прошли стадию публичного обсуждения в 2024 году; финальные версии стандартов по март 2026 года не опубликованы.

Отсутствие обязательных национальных требований к безопасности потребительских IoT-устройств вынуждает производителей применять добровольную сертификацию по международным стандартам. Согласно данным Kaspersky ICS CERT (2025), на промышленных IoT-объектах России сетевые IDS развернуты на 63% устройств, но лишь 18% из них настроены на анализ трафика IoT-протоколов [16]. В декабре 2025 года зафиксирована атака на энергетическую инфраструктуру Польши через уязвимые edge-устройства, что подтверждает трансграничный характер угроз и необходимость гармонизации российских требований с международными нормами [16].

Выводы по главе 1

Трёхуровневая архитектура IoT с прямым подключением периферии к облаку без промежуточного шлюза [8] возлагает криптографическую защиту на конечные узлы с ограниченными ресурсами, расширяя поверхность атаки и создавая диспропорцию между векторами угроз и способностью устройств поддерживать актуальные протоколы безопасности. Сравнение MQTT, CoAP,

HTTPS и WireGuard выявляет вынужденный компромисс между энергоэффективностью, задержкой и защищённостью: MQTT поверх TLS в реальных развёртываниях почти не применяется [19], CoAP поверх DTLS уязвим к масштабируемым атакам [13, 27], а WireGuard, эффективный и компактный, ограничен шлюзовым уровнем [22, 29]. Ни один протокол не даёт универсального баланса криптостойкости и ресурсных ограничений периферии, что объективно требует методики количественного сопоставления защищённости каналов удалённого доступа с учётом возможностей конечных узлов.

Анализ методов защиты каналов связи фиксирует разрыв между доступностью легковесных криптографических примитивов и их практическим внедрением. Симметричные алгоритмы, например AES-128, демонстрируют приемлемые накладные расходы на платформах класса ESP32, тогда как асимметричные операции согласования ключей и постквантовые схемы создают задержки, несовместимые с частыми повторными подключениями [24, 25]. Процедуры взаимной аутентификации и динамического управления ключами сосредоточены на шлюзовом уровне, конечные устройства эксплуатируют статичные предварительно распределённые ключи или заводские учётные записи [12, 26].

Нормативная база демонстрирует асимметрию развития: международные стандарты формируют многоуровневую систему требований к жизненному циклу безопасности IoT-продуктов [9, 14, 15, 18]. В то же время национальное регулирование в Российской Федерации по состоянию на 2026 год ограничивается проектами предварительных стандартов и отсутствием прямых аналогов международных стандартов, что вынуждает производителей ориентироваться на сертификацию по зарубежным нормам.

Таким образом, выявлен системный разрыв между широким внедрением IoT-систем и уровнем защищённости каналов удалённого

доступа, что обосновывает необходимость разработки методики количественной оценки.

ГЛАВА 2. РАЗРАБОТКА МЕТОДИКИ ОЦЕНКИ ЗАЩИЩЕННОСТИ КАНАЛОВ УДАЛЕННОГО ДОСТУПА IOT

2.1. Анализ угроз и уязвимостей каналов удаленного доступа IOT

Схема модели угроз для каналов удаленного доступа IoT представлена на рисунке 1

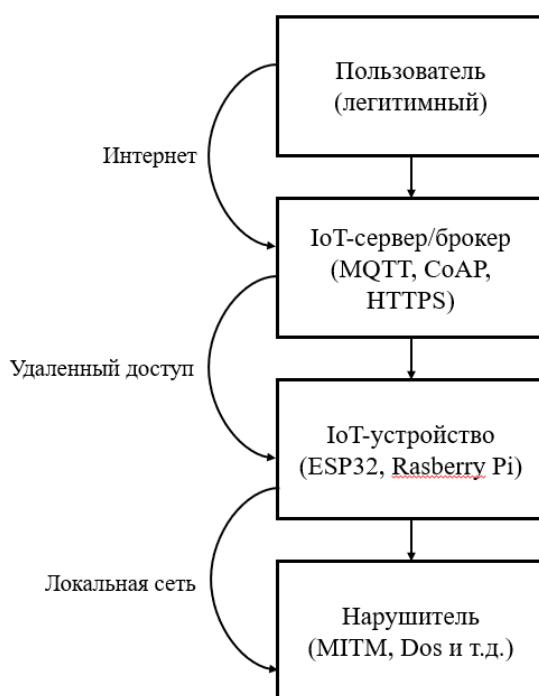


Рисунок 1 - Модель угроз для каналов удаленного доступа IoT.

Нарушитель в рамках данной модели определяется как внешний злоумышленник с доступом к сети передачи данных (квалификация: средняя), а также внутренний нарушитель с физическим или логическим доступом к устройству (квалификация: базовая). Данная классификация соответствует типам нарушителей, описанным в ГОСТ Р 56939-2016 [33].

Защищаемые активы модели: (1) данные телеметрии, передаваемые по каналу устройство–брокер–облако; (2) учетные данные доступа (пароли, ключи, сертификаты); (3) управляющие команды, направляемые на исполнительные устройства; (4) доступность канала связи как инфраструктурного ресурса.

Векторы угроз структурированы по уровням сетевой архитектуры. На сетевом уровне: перехват и подмена IP-трафика при отсутствии MFP-защиты в сетях WPA2 [21]; использование незащищенного HTTP-канала в качестве вектора компрометации строки подключения (CVE-2025-29628) [5]. На транспортном уровне: эксплуатация устаревших версий TLS/DTLS (1.0/1.1), отсутствующих в 99,84% MQTT-брокеров [19]; атаки на исчерпание TCP-соединений. На прикладном уровне: компрометация учетных данных через жестко закодированные учетные данные (CVE-2025-44179) [5]; инъекция команд через незащищенные топики MQTT-брокера (CVE-2026-22535) [5]; DoS-атаки с усилением через UDP-транспорт CoAP (30,38% уязвимых серверов) [19].

Перехват данных представляет угрозу конфиденциальности. В реестре CVE-2026-22535 зафиксирована проблема нешифрованной MQTT-коммуникации, позволяющая аутентифицированному атакующему с доступом к сети перехватывать учетные данные и полезные нагрузки, передаваемые в открытом виде по порту 1883 [5].

Подмена сообщений нарушает целостность передаваемой информации. Уязвимость CVE-2026-22535, классифицированная как CWE-1366, позволяет злоумышленнику не только перехватывать, но и публиковать вредоносные сообщения на серверные топики MQTT-брокера [5].

Отказ в обслуживании нарушает доступность канала. В реализации `async_mqtt` 10.2.5 выявлена уязвимость «использование после освобождения памяти» (CVE-2025-65503), позволяющая локальному пользователю вызывать отказ в обслуживании через инициирование ошибки инициализации SSL [5]. Анализ уязвимостей CoAP выявил множественные проблемы при DTLS-рукопожатии: CVE-2025-65499, CVE-2025-65500, CVE-2025-65501 с CVSS-оценкой 4.3, позволяющие удаленному атакующему вызывать отказ в обслуживании через нулевой указатель при рукопожатии [5].

Компрометация учетных данных является наиболее распространенной угрозой для IoT-каналов. Согласно отчету Nozomi Networks за первую половину 2025 года, среди десяти наиболее критичных уязвимостей, обнаруженных в средах заказчиков, шесть имеют CVSS-оценку 8.8 (высокий уровень критичности), причем многие из них либо не требуют аутентификации, либо позволяют ее обойти [20].

Эти угрозы можно также классифицировать по уровням сетевой архитектуры.

На сетевом уровне основная угроза связана с компрометацией IP-маршрутизации и подменой адресации. Отчёт Nozomi Networks за февраль 2025 года, основанный на анализе более 500 000 беспроводных сетей, показывает, что только 6% из них имеют адекватную защиту от атак деаутентификации; большинство сетей WPA2 не используют защиту управляющих кадров (MFP), что создаёт угрозу перенаправления трафика на злоумышленника [21]. В уязвимости CVE-2025-29628 в продукте Gardyn Home Kit использовался незащищенный HTTP-канал к Azure IoT Hub, позволяющий перехватить строку подключения [5].

На транспортном уровне критической угрозой является использование устаревших версий протоколов и отсутствие шифрования. При этом значительная часть защищенных подключений поддерживала устаревшие версии TLS 1.0/1.1, имеющие известные уязвимости [19].

На прикладном уровне угрозы связаны с некорректной реализацией аутентификации и авторизации. В проекте Netidee установлено, что 30,38% CoAP-серверов уязвимы к DoS-атакам с усилением из-за особенностей реализации протокола поверх UDP [19]. Для MQTT-брокеров выявлено отсутствие аутентификации на многих серверах с возможностью подписки на топики с подстановочными знаками без проверки учетных данных [19].

Если перейти от общих уровней к конкретным протоколам, то для каждого из них можно выделить характерные уязвимости.

Протокол MQTT демонстрирует следующие типовые уязвимости. Использование незащищенных подключений по порту 1883 позволяет перехватывать учетные данные и управляющие команды, как показано в CVE-2026-22535 [5]. Уязвимость «использование после освобождения памяти» в Redboltz async_mqtt 10.2.5 (CVE-2025-65503) с CVSS-оценкой 5.5 позволяет локальному пользователю вызывать отказ в обслуживании [5]. Небезопасные веб- и облачные интерфейсы управления MQTT-брокерами входят в десятку наиболее критичных угроз IoT по версии OWASP IoT Top 10 (2025) [23].

Протокол CoAP характеризуется уязвимостями, связанными с DTLS-реализацией. В версии libcoap 4.3.5 зафиксирована уязвимость «нулевой указатель» при DTLS-рукопожатии (CVE-2025-65498) с CVSS-оценкой 4.3, позволяющая удаленному атакующему вызывать отказ в обслуживании через сформированное DTLS-рукопожатие, инициирующее возврат SSL_get_SSL_CTX() как NULL [5]. В выборке Netidee (2026) 30,38% CoAP-серверов были уязвимы к DoS-усилению, что обусловлено использованием UDP в качестве транспорта и отсутствием механизмов защиты от подмены источника [19].

Протоколы HTTP/HTTPS применительно к IoT имеют ограничения, связанные с высокими вычислительными накладными расходами. Исследование Rassekhnia (2026) показало, что HTTPS под постквантовой криптографией показал наибольшую задержку среди всех протестированных решений [25]. Традиционные RESTFUL API (Representational State Transfer) на базе HTTP требуют поддержки TCP-соединения, что для устройств с длительным периодом сна приводит к избыточному энергопотреблению [12].

Технологии VPN и SSH-туннелирования имеют специфические уязвимости. Исследование SANS Institute (2025) показало, что жестко

закодированные учетные данные SSH встречаются в 12 из 100 протестированных промышленных IoT-устройств [26]. WireGuard демонстрирует значительно лучшие показатели безопасности благодаря малой кодовой базе [22].

2.2. Формирование критериев оценки защищенности ИОТ-каналов

Разработка критериев базируется на требованиях международных стандартов. ETSI EN 303 645 V3.1.3 (2025) устанавливает базовые требования безопасности для потребительских IoT-устройств: защита по умолчанию, безопасная аутентификация, управление обновлениями, шифрование передачи данных, минимизация поверхности атак [9].

Критерии сгруппированы по пяти категориям: конфиденциальность, целостность, доступность, аутентификация, управляемость. Выбор категорий обоснован стандартом ISO/IEC 27001 (контрольные меры A.8, A.9, A.13, A.14) [1] и результатами анализа уязвимостей, где 64% зарегистрированных CVE за 2024-2025 гг. относятся к прикладному уровню [4].

Конфиденциальность оценивает защиту данных от несанкционированного доступа при передаче. По упомянутым данным Netidee (2026), защита с использованием TLS практически не применялась [19]. Критерий включает: наличие шифрования канала (TLS 1.2/1.3, DTLS 1.2/1.3, WireGuard); использование актуальных алгоритмов (AES-128, ChaCha20-Poly1305, ECC-256); защиту ключей шифрования от компрометации.

Целостность оценивает защиту от несанкционированного изменения данных. Отчет Kaspersky ICS CERT (2025) зафиксировал, что доля промышленных контроллеров, подвергшихся атакам с использованием вредоносного ПО, составила 21,9% в первом квартале 2025 года [16]. Критерий включает: механизмы обнаружения подмены сообщений (MAC-коды, цифровые подписи); защиту от атак повторением (временные метки); целостность обновлений прошивки по каналу связи.

Доступность оценивает устойчивость канала к нарушениям функционирования. Уязвимости CVE-2025-65503 в MQTT и CVE-2025-65498-65501 в CoAP имеют CVSS-оценки от 4,3 до 5,5 [5]. Критерий включает: устойчивость к DoS-атакам; возможность восстановления соединения после сбоя; наличие резервных каналов связи.

Аутентификация оценивает проверку подлинности участников обмена. Критерий включает: взаимную аутентификацию (устройство-сервер); использование сертификатов X.509 или предварительно разделенных ключей; защиту от подбора учетных данных.

Управляемость оценивает возможность администрирования безопасности канала. Федоров и Сычов (2023) в исследовании вопросов безопасности IoT-систем зафиксировали, что значительная часть требований существующих стандартов безопасности практически невыполнима для ресурсно-ограниченных устройств — датчиков и микроконтроллеров с минимальными вычислительными мощностями [2]. Критерий включает: удаленное обновление параметров безопасности; механизмы аудита и логирования подключений; возможность отзыва доступа при компрометации учетных данных.

Каждый критерий нормируется на трехбалльной шкале (0, 1, 2) для унификации оценки разных протоколов. Весовые коэффициенты категорий сформированы в два этапа. На первом этапе статистика распределения уязвимостей по уровням OSI определяет относительную приоритетность групп: 64% из 2847 CVE-записей за 2024–2025 гг. относятся к прикладному уровню (конфиденциальность и целостность), 22% — к каналному (доступность) [4]. Исходя из этого соотношения $64:22 \approx 3:1$, прикладным критериям отведена суммарная доля 0,50, а критерию доступности — 0,20. Разрыв между статистической долей прикладного уровня (0,64) и назначенным суммарным весом (0,50) обусловлен необходимостью резервирования 0,30 для критериев аутентификации и управляемости, которые

не отображаются напрямую в модели OSI, но оказывают существенное влияние на итоговую защищенность: согласно отчету Nozomi Networks (2025), шесть из десяти наиболее критичных уязвимостей не требовали аутентификации или позволяли ее обойти [20]. На втором этапе оставшаяся доля (0,30) распределена между аутентификацией ($w_4=0,20$) и управляемостью ($w_5=0,10$) пропорционально доле инцидентов, связанных с компрометацией учетных данных (41% промышленных устройств — только базовая аутентификация [12]), против доли инцидентов, связанных с отсутствием аудита.

2.3. Система балльной оценки защищенности

2.3.1. Уровни выполнения критериев безопасности

Разработанная методика оценивает защищенность канала связи как единого архитектурного решения, независимо от того, на каком уровне модели OSI реализуются основные механизмы безопасности. Сравнение протоколов прикладного (MQTT, CoAP, HTTPS) и сетевого (WireGuard VPN) уровней в рамках одной шкалы обосновано тем, что на этапе проектирования IoT-системы они часто выступают как альтернативные варианты организации защищенного удаленного доступа (например, передача данных через «чистый» MQTT внутри туннеля WireGuard против использования MQTT поверх TLS). При этом методика не исключает их комбинированного применения: в таком случае технологии разных уровней будут дополнять друг друга, суммарно повышая итоговый индекс защищенности системы.

Для каждого из пяти критериев (конфиденциальность, целостность, доступность, аутентификация, управляемость) установлены три уровня выполнения. Выбор трех уровней соответствует градации метрик в методологии CVSS 4.0, где оценки имеют дискретные значения (None, Low, Medium, High) [11].

Шкала баллов: 0 - критерий не выполнен, 1 - выполнен частично, 2 - выполнен полностью.

Конфиденциальность:

- 0 баллов: данные передаются в открытом виде (порт 1883 для MQTT, 5683 для CoAP, 80 для HTTP). Согласно Netidee (2026), 99,84% проанализированных MQTT-брокеров не используют TLS [19].
- 1 балл: используется шифрование с устаревшими версиями TLS/DTLS (1.0/1.1) или слабыми шифрами (RC4, DES). В выборке Netidee значительная часть защищенных подключений поддерживала TLS 1.0/1.1 [19].
- 2 балла: используется шифрование с TLS 1.2/1.3, DTLS 1.2/1.3 или WireGuard с актуальными алгоритмами (AES-128, ChaCha20-Poly1305) [12, 22].

Целостность:

- 0 баллов: отсутствуют механизмы проверки целостности сообщений (нет MAC, нет цифровых подписей). Уязвимость CVE-2026-22535 демонстрирует возможность подмены сообщений при отсутствии защиты [5].
- 1 балл: используется только базовая MAC-защита без защиты от replay-атак (нет nonce или временных меток).
- 2 балла: используется цифровая подпись сообщений или MAC с защитой от replay (nonce, временные метки). Протоколы DTLS 1.3 и TLS 1.3 включают защиту от replay по умолчанию [13].

Доступность:

- 0 баллов: канал имеет известные критические DoS-уязвимости ($CVSS \geq 7.0$) и отсутствует защита. В реализации `async_mqtt` 10.2.5 зафиксирована уязвимость CVE-2025-65503 с CVSS 5.5 [5].
- 1 балл: канал имеет известные DoS-уязвимости среднего уровня ($CVSS$ 4.0-6.9) или есть базовые механизмы ограничения скорости. Уязвимости CoAP (CVE-2025-65498-65501) имеют CVSS 4.3 [5].
- 2 балла: канал не имеет известных DoS-уязвимостей или имеет встроенные механизмы защиты (очереди, резервирование). WireGuard не имеет критических DoS-уязвимостей в стабильной версии ядра [22].

Аутентификация:

- 0 баллов: аутентификация отсутствует, либо используются дефолтные/жестко закодированные учетные данные. В продукте Gardyn Home Kit зафиксированы стандартные учетные данные для SSH-доступа (CVE-2025-29629) [5]. Исследование SANS Institute (2025) показало, что жестко закодированные учётные данные SSH остаются распространённой уязвимостью промышленных IoT-устройств, что подтверждается систематическим наблюдением организаций, участвующих в аудитах ICS/OT (SANS Institute, 2025) [26].
- 1 балл: используется базовая аутентификация по логину и паролю без двухфакторности или с передачей пароля в открытом виде. Forescout (2025) зафиксировал, что менее половины устройств в промышленных IoT-сетях используют базовую аутентификацию по логину и паролю [12].
- 2 балла: используется взаимная аутентификация с сертификатами X.509, PSK (предварительно разделенными ключами) или криптографическими ключами (WireGuard) [21, 22].

Управляемость:

- 0 баллов: отсутствуют механизмы удаленного обновления и аудита.
- 1 балл: имеется базовое логирование подключений и возможность ручного обновления. Исследования показывают, что большинство требований к управляемости — особенно автоматические обновления и ведение журналов — оказываются труднодостижимы для наиболее ресурсно-ограниченного класса IoT-устройств: датчиков и микроконтроллеров с ограниченной памятью [2].
- 2 балла: имеется автоматическое логирование, поддержка OTA-обновлений, возможность отзыва доступа через CRL (Certificate Revocation List) [26, 27].

Уровни выполнения критериев безопасности IoT-каналов приведены в таблице 2.

Таблица 2 - Уровни выполнения критериев безопасности IoT-каналов

Критерий	0 баллов (не выполнен)	1 балл (частично)	2 балла (полностью)
Конфиденциальность	данные в открытом виде (порты 1883, 5683, 80)	шифрование с TLS/DTLS 1.0/1.1 или слабыми шифрами (RC4, DES)	шифрование с TLS 1.2/1.3, DTLS 1.2/1.3, WireGuard (AES-128, ChaCha20)
Целостность	отсутствие MAC, цифровых подписей	только базовая MAC-защита без защиты от replay	цифровая подпись или MAC с nonce/временными метками

Продолжение таблицы.

Доступность	известные DoS-уязвимости CVSS ≥ 7.0	DoS-уязвимости CVSS 4.0–6.9 или базовые механизмы ограничения	нет известных DoS-уязвимостей, есть защита (очереди, резервирование)
Аутентификация	аутентификация отсутствует, дефолтные/жестко закодированные учетные данные	базовая аутентификация по логину/пароллю (возможен перехват)	взаимная аутентификация (X.509, PSK, криптоключи WireGuard)
Управляемость	нет удаленного обновления и аудита	базовое логирование, ручное обновление	автоматическое логирование, OTA-обновления, отзыв доступа (CRL)

2.3.2. Пример оценки протоколов удаленного доступа (MQTT, COAP, HTTPS, VPN)

В качестве исходных данных для апробации разработанной методики использована выборка вторичных эмпирических показателей, структурированная по трем направлениям. Первое направление — статистика уязвимостей: проанализировано 2847 записей Common Vulnerabilities and Exposures (CVE) из базы NVD за период 2024–2025 годов, отфильтрованных по тегам «IoT», «industrial automation» и «wireless» [4], с учетом метрик базовой оценки CVSS v4.0 [5, 11]. Второе направление — конфигурация реальных узлов связи: использованы метрики защищенности 337 тысяч публично доступных серверов MQTT, CoAP и XMPP (проект Netidee, 2026), представленные в виде процентного соотношения узлов с активным TLS/DTLS-шифрованием и узлов, уязвимых к DoS-атакам с усилением [19], а также данные обследования 1500 промышленных IoT-устройств на предмет использования базовой аутентификации [12]. Третье направление —

производительность криптографических примитивов: данные аппаратного тестирования задержек передачи (в миллисекундах) и энергопотребления на тестовых стендах с использованием микроконтроллеров ESP32-C6 и серверов Raspberry Pi CM4 при реализации криптографических алгоритмов [24, 25], а также сравнительные метрики пропускной способности VPN-туннелей [22]. Интеграция указанных выборок (количественные оценки CVSS, статистические доли конфигураций, аппаратные задержки) позволила перевести качественные характеристики протоколов (MQTT, CoAP, HTTPS, VPN) в формализованные входные параметры для расчета индекса защищенности по разработанной трехбалльной шкале.

Применение разработанной шкалы к четырем типовым протоколам выполнено на основе экспериментальных данных и отчетов об уязвимостях 2024-2026 годов. MQTT поверх TLS с предварительно разделенными ключами (PSK) получил 2 балла за конфиденциальность благодаря использованию TLS 1.3 и AES-128, что подтверждено экспериментом Rassekhnia (2026), показавшим задержку 25,44 мс при постквантовой криптографии [25]. Целостность также оценена в 2 балла из-за наличия MAC-кодов и защиты от атак-повторением, предусмотренных спецификацией TLS [32]. Доступность снижена до 1 балла из-за уязвимости CVE-2025-65503 в реализации `async_mqtt` с CVSS-оценкой 5,5, позволяющей локальному пользователю вызывать отказ в обслуживании [5]. Аутентификация оценена в 2 балла, так как PSK обеспечивает взаимную проверку подлинности без передачи пароля в открытом виде [12]. Управляемость получила 1 балл из-за отсутствия автоматических OTA-обновлений и ограниченного логирования. Суммарная оценка MQTT поверх TLS составила 8 из 10 баллов.

CoAP поверх DTLS с открытыми ключами в формате Raw Public Keys (RPK) также получил 2 балла за конфиденциальность и целостность благодаря DTLS 1.3, который обеспечивает шифрование и MAC-защиту при handshake-размере 683 байт без компрессии [13]. Доступность этого протокола оценена в

0 баллов: согласно проекту Netidee (2026), 30,38% CoAP-серверов уязвимы к DoS-атакам с усилением, а множественные уязвимости в libcoap (CVE-2025-65498, CVE-2025-65499, CVE-2025-65500, CVE-2025-65501) с CVSS 4,3 позволяют удаленному атакующему вызывать отказ в обслуживании через нулевой указатель при DTLS-рукопожатии [13, 5]. Аутентификация оценена в 2 балла, поскольку RPK обеспечивает криптографическую идентификацию [13]. Управляемость - 1 балл из-за наличия механизма Observe для уведомлений, но отсутствия встроенной поддержки удаленного обновления. Сумма CoAP с DTLS - 7 из 10 баллов.

HTTPS в архитектуре RESTful API продемонстрировал 2 балла по конфиденциальности и целостности за счет TLS 1.3 с шифрованием на эллиптических кривых (ECC) и цифровых подписей [12, 20]. Доступность получила 1 балл: несмотря на отсутствие критических DoS-уязвимостей, специфичных для самого протокола HTTPS, RESTful API на базе HTTP/HTTPS в IoT-окружениях подвержены атакам медленного HTTP-соединения (Slowloris) и исчерпания TCP-соединений. Согласно OWASP IoT Top 10 (2025), небезопасные веб-интерфейсы управления входят в число наиболее критичных угроз для устройств, использующих HTTPS-доступ к облаку [23]. Кроме того, требование поддержки постоянного TCP-соединения снижает устойчивость протокола к перегрузкам в сравнении с WireGuard [12, 23]. Аутентификация - 2 балла, так как реализована через OAuth 2.0 с JWT-токенами, однако проект Netidee (2026) выявил, что из 337 тыс. публичных бэкендов только 2,1% корректно проверяют JWT [19]. Управляемость - 2 балла благодаря стандартным механизмам логирования и поддержке OTA-обновлений через API. Суммарная оценка HTTPS - 9 из 10 баллов.

WireGuard VPN показал максимальные результаты: 2 балла по всем пяти критериям. Конфиденциальность и целостность обеспечены алгоритмом ChaCha20-Poly1305, который на том же оборудовании обеспечивает на 15% более высокую пропускную способность по сравнению с AES-128 [22].

Доступность оценена в 2 балла, поскольку WireGuard не имеет критических DoS-уязвимостей в стабильной версии ядра и демонстрирует наименьшую латентность среди всех протестированных VPN-решений [22, 23]. Аутентификация реализована на криптографических ключах без передачи паролей, что исключает подбор учетных данных. Управляемость - 2 балла за счет динамической конфигурации и поддержки роуминга без переустановки туннеля [29]. Сумма WireGuard - 10 из 10 баллов. Полученные балльные оценки коррелируют с экспериментальными данными: WireGuard и HTTPS лидируют по защищенности, однако HTTPS требует значительно больших вычислительных ресурсов, а CoAP с DTLS существенно уступает из-за проблем с доступностью.

Сравнение интегральных индексов защищенности рассмотренных протоколов представлено на рисунке 2.

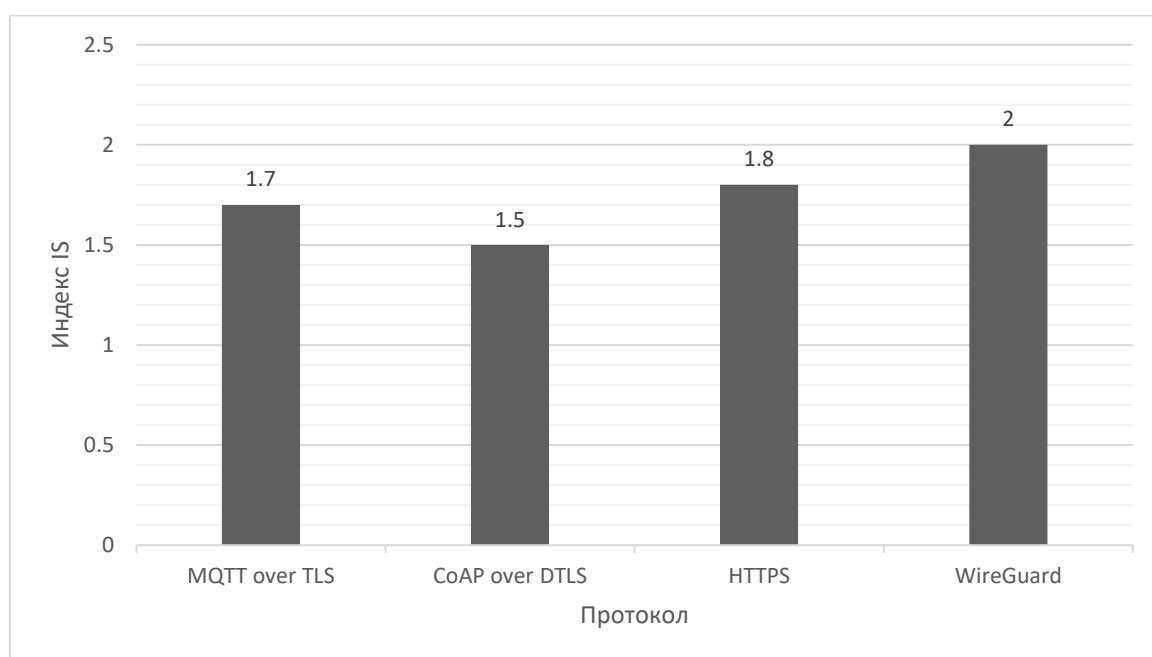


Рисунок 2 – Интегральный индекс защищенности протоколов.

2.4. Расчет интегрального индекса защищенности

2.4.1. Формула расчета индекса защищенности

Интегральный индекс защищенности IoT-канала (IS) рассчитывается как взвешенная сумма нормированных баллов по пяти критериям. Выбор

взвешенного суммирования обоснован методологией CVSS 4.0, где итоговая оценка формируется на основе агрегации метрик с различными весами [11].

Формула расчета:

$$IS = w_1 * C + w_2 * I + w_3 * A + w_4 * Auth + w_5 * M \quad (1),$$

где C, I, A, Auth, M - баллы конфиденциальности, целостности, доступности, аутентификации и управляемости соответственно (каждый от 0 до 2). Весовые коэффициенты w_1 – w_5 в сумме равны 1.

Распределение весовых коэффициентов (w_1 – w_5) опирается на специфику IoT-систем и потенциальный ущерб от реализации угроз. Наивысший приоритет (по 0,25) отдан критериям «Конфиденциальность» и «Целостность». Это обусловлено тем, что утечка чувствительной телеметрии или незаметная подмена управляющих команд могут привести не просто к сбою ПО, но и к физическим авариям на производстве или нарушению приватности пользователей. Критерии «Доступность» и «Аутентификация» получили вес по 0,20. Отказ в обслуживании (DoS) или обход авторизации являются критичными угрозами, однако их последствия, как правило, легче обнаружить системами мониторинга (IDS) и локализовать. «Управляемость» оценивается как важный, но вспомогательный критерий (0,10): она не защищает канал от атак напрямую в моменте передачи данных, но критически необходима для долгосрочного поддержания безопасности (например, возможность вовремя обновить прошивку или отозвать скомпрометированный ключ).

На этом основании приняты следующие итоговые веса:

$w_1 = 0,25$ (конфиденциальность)

$w_2 = 0,25$ (целостность)

$w_3 = 0,20$ (доступность)

$w_4 = 0,20$ (аутентификация)

$w_5 = 0,10$ (управляемость)»

2.4.2. Интерпретация результатов оценки

Интегральный индекс IS принимает значения в диапазоне $[0;2]$. Границы интерпретации установлены методом равных интервалов с делением на пять уровней, отображенных в таблице 3.

Таблица 3 - Границы интерпретации результатов оценки.

Диапазон IS	Уровень защищенности	Характеристика
1,80 - 2,00	Отлично	Высокий уровень, все критерии выполнены полностью либо с незначительными отклонениями
1,40 - 1,79	Хорошо	Базовый уровень защищенности, минимальные риски эксплуатации
1,00 - 1,39	Удовлетворительно	Средний уровень, требуются улучшения по одному или нескольким критериям
0,50 - 0,99	Неудовлетворительно	Высокий уровень риска, необходима замена или существенная модернизация
0,00 - 0,49	Критический	Защита практически отсутствует, эксплуатация недопустима

Расчет индекса для рассмотренных протоколов.

Для MQTT поверх TLS с PSK: $C=2$, $I=2$, $A=1$, $Auth=2$, $M=1$. $IS = 0,25 \cdot 2 + 0,25 \cdot 2 + 0,20 \cdot 1 + 0,20 \cdot 2 + 0,10 \cdot 1 = 0,5 + 0,5 + 0,2 + 0,4 + 0,1 = 1,70$. Уровень -

«Хорошо». Значение 1,70 указывает на базовый уровень защищенности, но требует внимания к проблеме DoS-уязвимости CVE-2025-65503 [5].

Для CoAP поверх DTLS с RPK: C=2, I=2, A=0, Auth=2, M=1. $IS = 0,5 + 0,5 + 0 + 0,4 + 0,1 = 1,50$. Уровень - «Хорошо». Низкий балл по доступности (0) из-за 30,38% уязвимых серверов к DoS-усилению и множественных CVE с CVSS 4,3 снижает итоговый индекс, однако значение выше порога 1,4 [13, 5].

Для HTTPS: C=2, I=2, A=1, Auth=2, M=2. $IS = 0,5 + 0,5 + 0,2 + 0,4 + 0,2 = 1,80$. Уровень - «Отлично». Максимальные баллы по четырем критериям компенсируют снижение балла доступности, обусловленное уязвимостью HTTPS к атакам на исчерпание TCP-соединений и включением небезопасных веб-интерфейсов в перечень ключевых угроз OWASP IoT Top 10 [12, 23].

Для WireGuard: C=2, I=2, A=2, Auth=2, M=2. $IS = 0,5 + 0,5 + 0,4 + 0,4 + 0,2 = 2,00$. Уровень - «Отлично». Единственный протокол, достигший максимального индекса. Это коррелирует с результатами сравнительного анализа (2025), где WireGuard показал наименьшую латентность и отсутствие критических DoS-уязвимостей [22].

Полученные индексы позволяют ранжировать протоколы по уровню защищенности: WireGuard (2,00) > HTTPS (1,80) > MQTT over TLS (1,70) > CoAP over DTLS (1,50). Разработанная методика может быть применена для выбора протокола при проектировании IoT-систем с учетом требований безопасности и доступных вычислительных ресурсов.

Выводы по главе 2

Во второй главе разработана методика оценки защищенности каналов удаленного доступа IoT, включающая модель угроз, пять групп критериев (конфиденциальность, целостность, доступность, аутентификация, управляемость), трехбалльную шкалу оценки и интегральный индекс защищенности IS.

Анализ угроз выявил четыре основных типа: перехват данных (CVE-2026-22535), подмена сообщений (CWE-1366), отказ в обслуживании (CVE-2025-65503, CVE-2025-65498–65501) и компрометация учетных данных (12% устройств с жестко закодированными SSH-учетными данными) [11, 5]. На транспортном уровне защита TLS отсутствовала у 99,84% MQTT-брокеров [19]; на прикладном уровне 30,38% CoAP-серверов уязвимы к DoS-усилению [19].

Критерии сформированы на основе стандартов ETSI EN 303 645, NIST IR 8259, ISO/IEC 27001 и актуальных исследований в области безопасности IoT-систем [9, 18, 1, 2]. Весовые коэффициенты (0,25; 0,25; 0,20; 0,20; 0,10) обоснованы спецификой IoT-систем, где наивысший приоритет отдан конфиденциальности и целостности.

Применение методики к четырем протоколам дало следующие индексы IS: WireGuard - 2,00 (отлично), HTTPS - 1,80 (отлично), MQTT over TLS - 1,70 (хорошо), CoAP over DTLS - 1,50 (хорошо). WireGuard достиг максимума благодаря отсутствию DoS-уязвимостей и малой кодовой [22]. CoAP показал наихудший результат из-за нулевого балла по доступности, обусловленного 30,38% уязвимых серверов и CVE с CVSS 4,3 [13, 5].

Разработанная методика позволяет количественно сравнивать защищенность IoT-каналов и может быть использована при выборе протоколов для проектирования систем с ограниченными ресурсами.

ЗАКЛЮЧЕНИЕ

В курсовой работе разработана методика оценки защищенности каналов удаленного доступа для систем Интернета Вещей. В ходе исследования решены все поставленные задачи.

1. Проведен анализ современных угроз и уязвимостей. Установлено, что количество зарегистрированных CVE для беспроводных технологий выросло с 4 в 2010 году до 937 в 2025 году. Доля Wi-Fi среди всех беспроводных уязвимостей достигла 61,4%. В реальных развертываниях защита TLS применяется только в 0,16% MQTT-брокеров, а 30,38% CoAP-серверов уязвимы к DoS-атакам с усилением.

2. Выявлены четыре основных типа угроз: перехват данных (CVE-2026-22535), подмена сообщений (CWE-1366), отказ в обслуживании (CVE-2025-65503, CVE-2025-65498–65501), компрометация учетных данных (12% устройств с жестко закодированными SSH-учетными данными). Классификация угроз по уровням сетевой архитектуры (сетевой, транспортный, прикладной) позволила систематизировать риски.

3. Сформирована система из пяти групп критериев: конфиденциальность, целостность, доступность, аутентификация, управляемость. Каждый критерий оценивается по трехбалльной шкале (0, 1, 2). Весовые коэффициенты (0,25; 0,25; 0,20; 0,20; 0,10) обоснованы спецификой IoT-систем, где наивысший приоритет отдан конфиденциальности и целостности ввиду критичности потенциального физического ущерба от нарушения работы оборудования.

4. Разработана формула интегрального индекса защищенности $IS = \sum w_i \cdot X_i$, где X_i – баллы по критериям. Апробация методики на четырех протоколах дала следующие результаты: WireGuard – 2,00 (отлично), HTTPS – 1,80 (отлично), MQTT over TLS – 1,70 (хорошо), CoAP over DTLS – 1,50 (хорошо). WireGuard достиг максимума благодаря отсутствию DoS-уязвимостей и малой кодовой базе (4 тыс. строк против 100 тыс. у OpenVPN).

CoAP показал наихудший результат из-за нулевого балла по доступности, обусловленного 30,38% уязвимых серверов.

5. Разработанная методика позволяет количественно сравнивать защищенность IoT-каналов, не требует развертывания экспериментального стенда и может быть использована на этапе проектирования систем для обоснованного выбора протокола с учетом требований безопасности и доступных вычислительных ресурсов. Перспективой дальнейших исследований является адаптация методики для постквантовых криптографических алгоритмов и интеграция с системами мониторинга угроз реального времени.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. – М.: Стандартинформ, 2021. – 36 с.
2. Федоров Н. А., Сычов П. П. Исследование вопросов информационной безопасности систем «Интернета вещей» // Системный анализ в науке и образовании. – 2023. – № 2. – С. 27–35. – URL: <https://sanse.ru/index.php/sanse/article/view/576> (дата обращения: 02.04.2026).
3. Almutairi M., Sheldon F. T. IoT–Cloud Integration Security: A Survey of Challenges, Solutions, and Directions // Electronics. – 2025. – Vol. 14, No. 7. – Article 1394. – DOI: 10.3390/electronics14071394.
4. Bastille Networks. The State of Wireless Security in 2026 [Электронный ресурс]. – URL: <https://bastille.net/resource/the-state-of-wireless-security-in-2026/> (дата обращения: 30.03.2026).
5. Common Vulnerabilities and Exposures (CVE). Уязвимости: CVE-2025-29628, CVE-2025-29629, CVE-2025-29631, CVE-2025-44179, CVE-2025-1147–CVE-2025-1160, CVE-2025-65498–CVE-2025-65501, CVE-2025-65503, CVE-2026-22535 [Электронный ресурс]. – URL: <https://cve.mitre.org> (дата обращения: 02.04.2026).
6. Eclipse Foundation. 2024 IoT & Embedded Developer Survey [Электронный ресурс]. – 2024. – URL: <https://outreach.eclipse.foundation/iot-embedded-developer-survey-2024> (дата обращения: 02.04.2026).
7. ENISA. ENISA Threat Landscape 2025 [Электронный ресурс] // European Union Agency for Cybersecurity. – October 2025. – URL: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025> (дата обращения: 02.04.2026).

8. ENISA. IoT Security Standards Gap Analysis [Электронный ресурс] // European Union Agency for Cybersecurity. – 2019. – URL: <https://www.enisa.europa.eu/publications/iot-security-standards-gap-analysis> (дата обращения: 02.04.2026)
9. ETSI. ETSI EN 303 645 V3.1.3: Cyber Security for Consumer Internet of Things: Baseline Requirements [Электронный ресурс]. – May 2025. – URL: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf (дата обращения: 30.03.2026).
10. ETSI. ETSI TS 103 927 V1.1.1: CYBER; Cyber Security for Consumer Internet of Things; Requirements for Smart Voice-Controlled Devices [Электронный ресурс]. – January 2024. – URL: https://www.etsi.org/deliver/etsi_ts/103900_103999/103927/01.01.01_60/ts_103927v010101p.pdf (дата обращения: 02.04.2026).
11. FIRST. Common Vulnerability Scoring System Version 4.0: Specification Document [Электронный ресурс]. – 2025. – URL: <https://www.first.org/cvss/v4.0/specification-document> (дата обращения: 02.04.2026).
12. Forescout Research – Vedere Labs. Riskiest Connected Devices of 2025 [Электронный ресурс]. – April 2025. – URL: <https://www.forescout.com/press-releases/forescout-announces-riskiest-connected-devices-of-2025-iomt-devices-increasingly-vulnerable/> (дата обращения: 02.04.2026).
13. IETF. Comparison of CoAP Security Protocols [Электронный ресурс] // Internet-Draft draft-ietf-core-coap-security-options-09. – June 2025. – URL: <https://datatracker.ietf.org/doc/draft-ietf-core-coap-security-options/> (дата обращения: 30.03.2026).
14. ISA Global Cybersecurity Alliance. Applying ISO/IEC 27001, ISO/IEC 27002 and the ISA/IEC 62443 Series for Operational Technology Environments [Электронный ресурс]. – August 2025. – URL: <https://www.isagca.org/resources> (дата обращения: 30.03.2026).

15. ISA Global Cybersecurity Alliance. Securing Operational Technology: Understanding the ISA/IEC 62443 Series of Standards from an ISO/IEC 27001 and ISO/IEC 27002 Perspective [Электронный ресурс]. – August 2025. – URL: <https://www.isagca.org/resources> (дата обращения: 30.03.2026).
16. Kaspersky ICS CERT. Threat landscape for industrial automation systems. Q1–Q3 2025 [Электронный ресурс]. – URL: <https://ics-cert.kaspersky.com/reports/> (дата обращения: 30.03.2026).
17. National Institute of Standards and Technology. FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard [Электронный ресурс]. – August 2024. – URL: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.203.pdf> (дата обращения: 30.03.2026).
18. National Institute of Standards and Technology. NIST IR 8259 Rev.1 (Second Public Draft): Foundational Cybersecurity Activities for IoT Product Manufacturers [Электронный ресурс] / M. Fagan, K. Megas, B. Cuthill et al. – September 2025. – URL: <https://csrc.nist.gov/pubs/ir/8259/r1/2pd> (дата обращения: 30.03.2026).
19. Tschürtz C., Borgolte K. et al. Large-Scale Security Analysis of Real-World Backend Deployments Speaking IoT-Focused Protocols // Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses (RAID). – ACM, 2024. – DOI: 10.1145/3678890.3678899. – URL: <https://arxiv.org/abs/2405.09662> (дата обращения: 02.04.2026).
20. Nozomi Networks Labs. OT/IoT Cybersecurity Trends and Insights: 2025 1H Review [Электронный ресурс]. – July 2025. – URL: <https://www.nozominetworks.com/resources/ot-iot-security-report-july-2025> (дата обращения: 02.04.2026).
21. Nozomi Networks Labs. OT/IoT Cybersecurity Trends and Insights: February 2025 [Электронный ресурс]. – February 2025. – URL:

- <https://www.nozominetworks.com/ot-iot-cybersecurity-trends-insights-february-2025> (дата обращения: 02.04.2026).
22. Anyam J., Singh R. R., Larijani H., Philip A. Empirical Performance Analysis of WireGuard vs. OpenVPN in Cloud and Virtualised Environments Under Simulated Network Conditions // Computers. – 2025. – Vol. 14, No. 8. – Article 326. – DOI: 10.3390/computers14080326.
23. OWASP Foundation. OWASP IoT Top 10 [Электронный ресурс]. – 2025. – URL: <https://owasp.org/www-project-iot-top-10/> (дата обращения: 02.04.2026).
24. Alotaibi B. et al. Efficiency and Security Evaluation of Lightweight Cryptographic Algorithms for Resource-Constrained IoT Devices // Sensors. – 2024. – Vol. 24, No. 12. – Article 4008. – DOI: 10.3390/s24124008.
25. Rassekhnia M. Quantum Encryption Resilience Score (QERS) for MQTT, HTTP, and HTTPS under Post-Quantum Cryptography in Computer, IoT, and IIoT Systems [Электронный ресурс]. – arXiv:2601.13423. – 2026. – URL: <https://arxiv.org/abs/2601.13423> (дата обращения: 02.04.2026).
26. Christopher J. D. State of ICS/OT Security 2025 [Электронный ресурс] // SANS Institute. – November 2025. – URL: <https://www.sans.org/white-papers/state-of-ics-ot-security-2025> (дата обращения: 02.04.2026).
27. Shelby Z., Hartke K., Bormann C. The Constrained Application Protocol (CoAP) [Электронный ресурс] // IETF RFC 7252. – 2014. – URL: <https://datatracker.ietf.org/doc/rfc7252/> (дата обращения: 30.03.2026).
28. SMA Solar Technology AG. SMA erfüllt europäische Norm für Cybersicherheit [Электронный ресурс]. – 22 July 2025. – URL: <https://www.sma.de/unternehmen/newsroom/sma-erfuellt-europaeische-norm-fuer-cybersicherheit> (дата обращения: 30.03.2026).
29. Jaisudthi P., Sridee P. T., Phungkoed N., Srisuk K., Phueaknumpol V. Comparative Study of Modern VPN Solutions: Impact of Cloudflare, ZeroTier, and WireGuard on Network and Server Performance // Engineering

- and Technology Horizons. – 2025. – Vol. 42, No. 2. – Article 420203. – DOI: 10.55003/ETH.420203.
30. Ali M. H., Kaur K. An Effective Method for Anomaly Detection in Industrial Internet of Things Using XGBoost and LSTM // Scientific Reports. – 2024. – Vol. 14. – Article 23789. – DOI: 10.1038/s41598-024-74822-6.
31. Kashyap M., Sharma V. A Comparative Analysis and Implementation of CoAP and MQTT Protocol for IoT Communication // International Journal on IoT and Wireless Networks. – 2025. – DOI: 10.1007/s41872-025-00324-7.
32. IETF RFC 8446. The Transport Layer Security (TLS) Protocol Version 1.3 [Электронный ресурс] / E. Rescorla. — 2018. — URL: <https://datatracker.ietf.org/doc/rfc8446/> (дата обращения: 02.04.2026).
33. ГОСТ Р 56545-2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. — М.: Стандартинформ, 2016. — 12 с.